Day 17 Task: Firewall policy

What is a firewall?

A firewall analyses the network traffic and determines either to allow or deny it depending on configured settings. The traffic may be filtered based on source and destination IP addresses, ports, protocols, connection state or applications.

For instance, a firewall may permit the transmission of HTTPS requests for a web server while denying any traffic trying to connect to the database through its port. Therefore, a firewall filters the traffic and ensures that the security policy of the organization is fulfilled.

How does a firewall work?

Firewalls process network traffic by analyzing the traffic against its configured rules.

Traffic inspection: the firewall examines incoming or outgoing packets/connections.

Rule matching: it analyzes the traffic against predefined rules using IP addresses, ports, protocols, connection state or applications.

Allow/deny: it allows or denies traffic depending on the rule match and policy.

Logging/monitoring: based on the configuration, the firewall logs traffic event(s).

The firewall may apply an allowlist policy, where only authorized traffic is permitted, or a denylist policy, where defined traffic is denied. The default deny policy is preferable in cases of strict security requirement environment.

Firewall Types

Packet-Filtering Firewall

Packet filtering involves the inspection of packets through the use of attributes like the source IP address, destination IP address, protocol, and port number. Packets are allowed or blocked depending on the set rules.

It is relatively easy and efficient, but the basic form of packet filtering does not provide a complete state inspection and does not deeply inspect application data.

Stateful Inspection Firewall

The stateful firewall keeps track of active connections and maintains information regarding their state. It uses this information to determine whether the packets are from legitimate and established communication.

For instance, it allows the return traffic from the authorized outgoing connection without having each packet separately defined in the rules.

Proxy or Application-Level Firewall

Proxy firewall acts as an intermediary between the client and the destination server. It can inspect the communication at the application level.It offers more detailed control than basic packet filtering but may introduce additional processing overhead.

Next-Generation Firewall (NGFW)

A next-generation firewall combines traditional traffic filtering with advanced capabilities such as application awareness, intrusion prevention, and threat intelligence integration.

Organizations use NGFWs to identify and control sophisticated network threats that may not be detected through basic port and IP filtering alone.

Host-Based Firewall

A host-based firewall runs on an individual computer or server and controls traffic entering or leaving that device. It helps protect the system even when it is connected to an otherwise trusted network.

Network-Based Firewall

A network-based firewall protects a network segment by filtering traffic between networks or security zones. It is commonly deployed at network boundaries or between internal network segments.

What Is Packet Filtering?

Packet filtering is a firewall technique that examines packet-header information to determine whether traffic should be allowed or blocked.

Typical filtering criteria include:

- Source and destination IP addresses
- Source and destination port numbers
- Transport protocols such as TCP and UDP
- Direction of traffic
- Network interface or connection state, depending on the firewall

For example, a rule may permit TCP traffic destined for port 443 while denying incoming connections to port 23, which is commonly associated with Telnet.

Packet filtering is useful for enforcing basic network access policies. However, simple packet filters may not detect malicious content hidden inside an otherwise permitted connection.

What Is a Stateful Firewall?

A stateful firewall monitors active network connections and keeps track of their state. It examines packets in the context of existing communication rather than treating every packet as an entirely independent event.

For example, when a user initiates an HTTPS connection to a website, a stateful firewall can recognize return traffic belonging to that established connection. It can reject unexpected packets that do not match a valid connection state.

Stateful inspection improves traffic control and reduces the need for manually defining rules for every response packet. However, it still needs appropriate security rules and does not replace other protections such as endpoint security or intrusion prevention.

Firewall Policy

A firewall policy is a set of rules that defines which network traffic is permitted and which traffic is denied. A good policy follows the principle of least privilege by allowing only the communication required for legitimate business or user activities.

Objectives of a Firewall Policy

- Prevent unauthorized network access.
- Allow necessary services and applications to communicate.
- Restrict access to sensitive systems and ports.
- Reduce the network's attack surface.
- Record relevant security events for monitoring and investigation.
- Ensure rules are reviewed and updated when requirements change.

Example of a Conceptual Firewall Policy

Rule	Traffic	Action	Reason
Allow established connections	Valid return traffic	Allow	Supports existing authorized communication
Allow HTTPS	TCP port 443 to an approved web server	Allow	Enables secure web access
Allow DNS	Approved DNS resolver traffic	Allow	Supports domain name resolution
Block Telnet	TCP port 23	Deny	Prevents insecure remote access
Restrict database access	Database ports from unauthorized networks	Deny	Protects sensitive data
Block other unsolicited inbound traffic	Unrequested incoming connections	Deny	Reduces unauthorized access risks

This is an illustrative policy, not a ready-to-deploy configuration. Real rules must reflect the network architecture and required services. DNS may use UDP or TCP, and established-connection rules must be implemented according to the specific firewall platform.

Firewall Best Practices

Organizations should apply a default-deny approach where appropriate, permit only necessary services, and restrict administrative access to trusted systems. Firewall software and firmware should be kept updated to address known vulnerabilities.

Administrators should review rules regularly, remove obsolete permissions, enable suitable logging, and monitor unusual traffic. Firewalls should also be combined with other security measures, including endpoint protection, secure authentication, network segmentation, and intrusion detection.

Limitations of Firewalls

Firewalls are an important layer of defense, but they cannot prevent every cyberattack. Malicious traffic may pass through permitted connections, and attackers may exploit vulnerabilities in applications or devices behind the firewall.

A firewall also cannot fully protect against threats such as phishing, compromised user credentials, or malware introduced through other channels. Effective security therefore requires a layered approach that combines firewalls with additional technical and organizational controls.

Malware, phishing, application vulnerabilities, and other threats.